تقرير تحليل حادثة: هجوم إخفاء المستخدمين والمفاتيح النظامية (T1564.002)

T1564.002 - Hide Artifacts: Hidden Users

رشيد منصور الراجحي

تقرير تحليل حادثة

معلومات التواصل			
الاسم الأول:	RASHEED	البريد الإلكتروني:	
الاسم الأخير:	AL-RAJEHI	رقم الهاتف:	
المسمى الوظيفي:	SOC Analyst	تاريخ التقرير:	30 سبتمبر 2025

معلومات عامة عن الحادثة			
العنوان:	هجوم إخفاء المستخدمين والمفاتيح النظامية	رقم التقنية:	T1564.002 - Hidden Users
تاريخ - وقت وقوع الحادثة:	29 سبتمبر 2025	التكتيكات:	Defense Evasion,
تاريخ / وقت اكتشاف الحادثة:	28 سبتمبر 2025 @ 08:57:36	مصدر الحادثة:	منصة Wazuh - جهاز DESKTOP-AGUDN4H
الفئة:	اختبار اختراق داخلي / محاكاة هجوم	النوع	هجوم إلكتروني - إخفاء الآثار

ملخص الحادثة

في الفترة من 28 إلى 30 سبتمبر 2025، تم اكتشاف هجوم متعدد المراحل على الجهاز DESKTOP-AGUDN4H.

التحليل أظهر محاكاة لهجوم T1564.002 الذي يهدف إلى إخفاء المستخدمين وتعديل المفاتيح النظامية الحرجة لتجنب الاكتشاف.

تم اكتشاف الهجوم عبر قاعدة Sysmon لمراقبة تكامل سجل النظام وقواعد Wazuh الخاصة بتقنية إخفاء المستخدمين.

بأكثر من طريقة عبر ATOMIC AND PAYLOAD

شرح الهجوم

اليوم الأول: 28 سبتمبر 2025

المرحلة الأولى: إخفاء المستخدمين التقليدي(08:56:31)

أولاً :لاحظنا أن المهاجم قام بتعديل مفتاح Winlogon\UserList التقليدي

الدليل :تنبيه Wazuh (قاعدة 110222) يظهر تعديل مفتاحSpecialAccounts\UserList

NT\CurrentVersion\Winlogon\SpecialAccounts\UserlistNT\CurrentVersion\Winlogon\SpecialAccounts\Userlist

تغيير ملكية المجموعة: من Administratorsإلى Domain Users

المرحلة الثانية: استهداف خدمة نقل البيانات هذه تمت بعد ان قمت بثبيت حمولة ضارة باستخدام MSFVENOM (23:39:32)

ثانياً :قام المهاجم بتعديل خدمة(BITS (Background Intelligent Transfer Service

الدليل :تنبيه Wazuh (قاعدة 594) يظهر تغيير checksum لمفتاحBITS

HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\BITS

المرحلة الثالثة: إخفاء نشاط التطبيقات(23:42:46)

ثالثاً :تم تعديل إعدادات BAM للمستخدم المستهدف

الدليل :تنبيه Wazuh (قاعدة 594) يظهر تعديلBAM UserSettings

HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\bam\State\UserSettings\S-1-5-21-2683549735-1919836698-619989629-1001

اليوم الثاني: 30 سبتمبر 2025

المرحلة الرابعة: التعديلات المتقدمة(17:08-17:16)

رابعاً :عاد المهاجم لتعديل إعدادات BAM مرة أخرى(17:08:10)

التحليل المتقدم للأدلة

تحليل نمط الهجوم

نمط ثابت في جميع الهجمات:

تغيير ملكية المجموعة من Administrators (S-1-5-32-544)إلى SYSTEM (S-1-5-18)

استخدام حساب SYSTEM ذو الصلاحيات العالية

استهداف مفاتيح نظام حرجة في أماكن غير متوقعة

تحليل المفاتيح المستهدفة

المفتاح	الوظيفة الخطورة	
Winlogon\UserList	إخفاء المستخدمين من شاشة التسجيل	إخفاء حسابات غير مصرح بها
BITS	خدمة نقل الخلفية الذكية إخفاء نقل البيانات الضارة	
BAM	مراقبة نشاط الخلفية	إخفاء نشاط التطبيقات الخبيثة

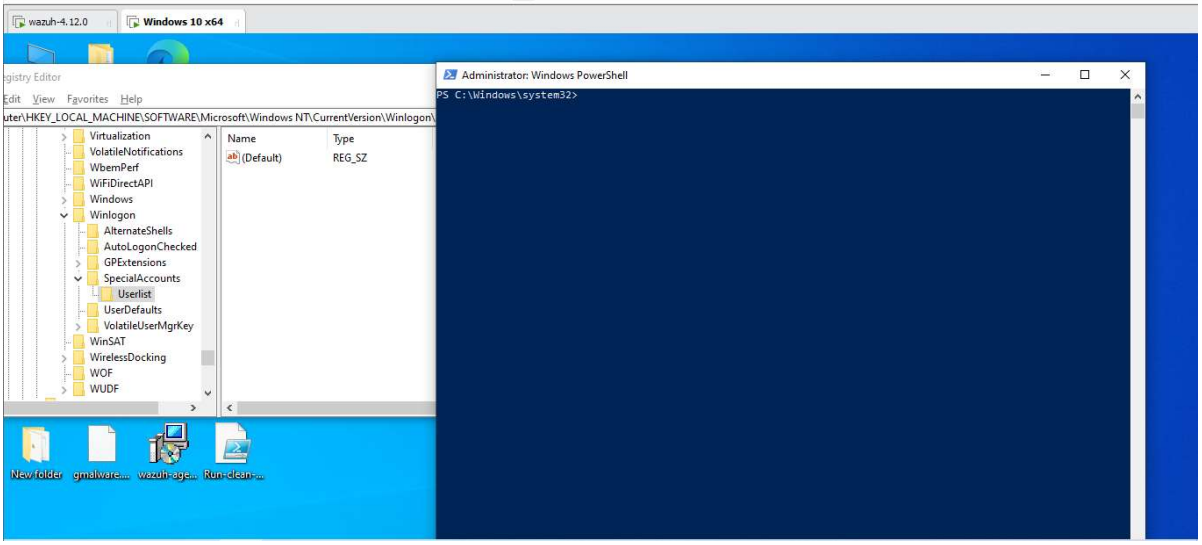
تحليل المستخدم المستهدف

SID: S-1-5-21-2683549735-1919836698-619989629-1001

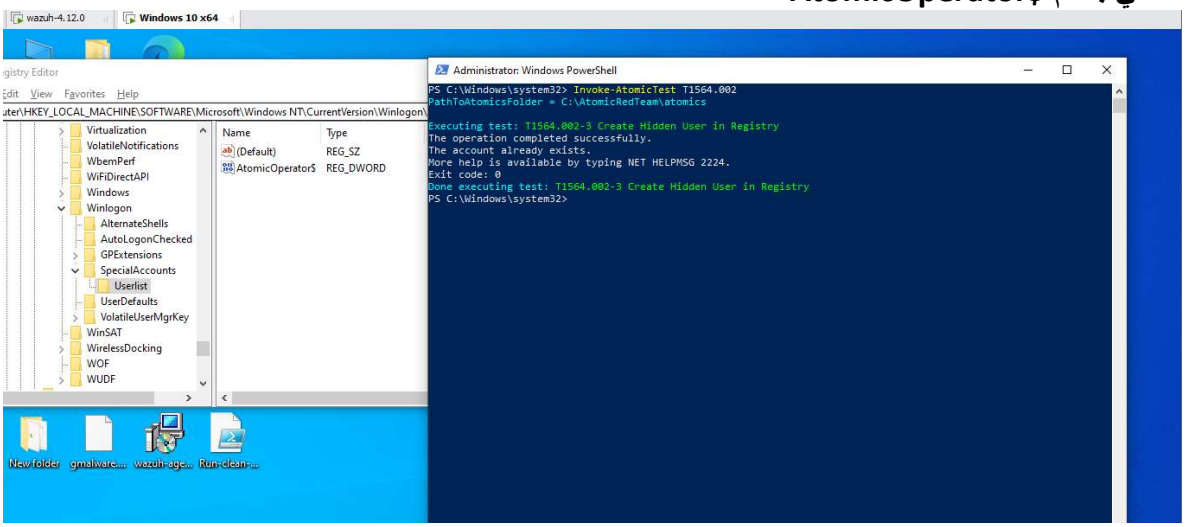
النمط :نفس المستخدم ظهر في تعديلات متعددة

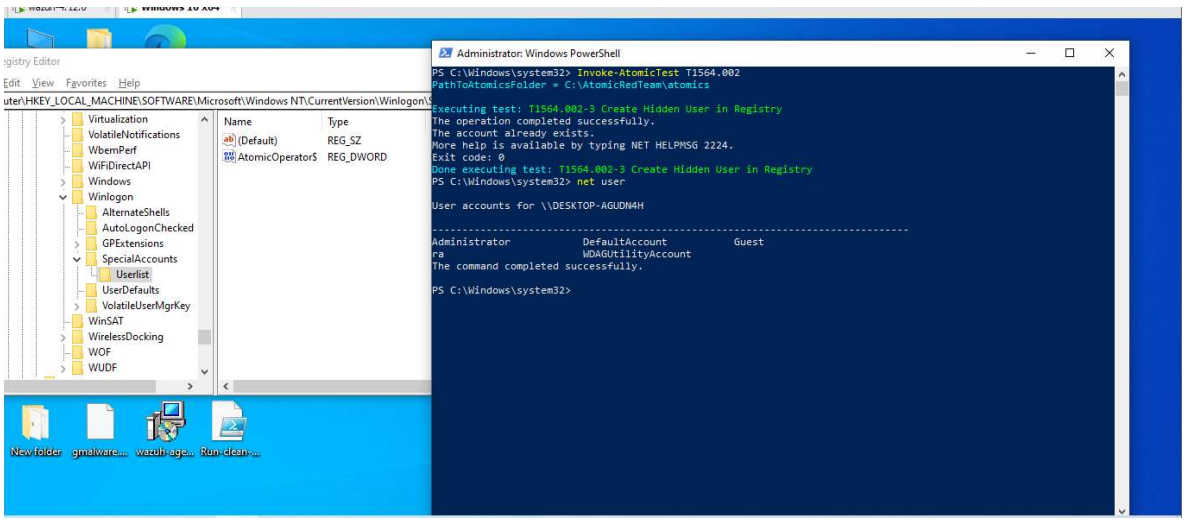
الاستنتاج :هجوم مركز على حساب مستخدم معين

لملاحظة بصرية REGISTERهنا بداية محاكاة الهجوم وفتح نافذة

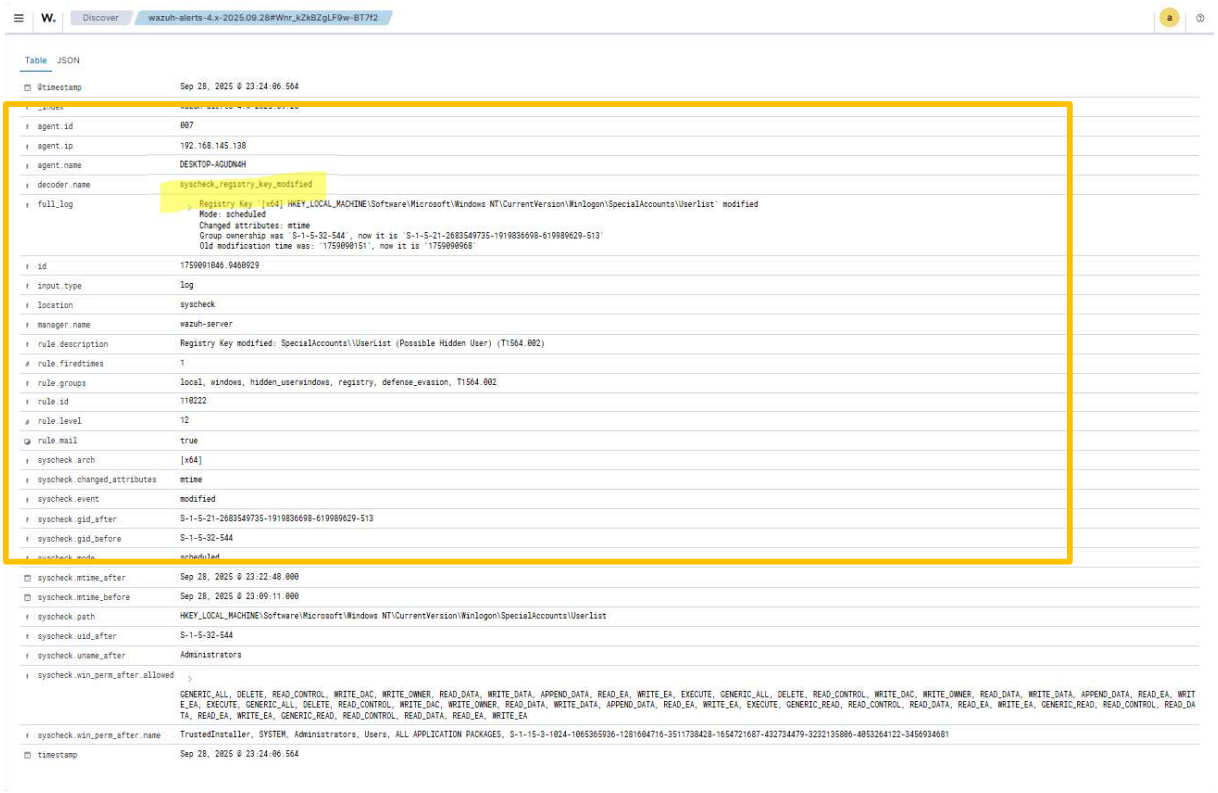


وهنا بعد تنفيذ تجربة الهجوم المحاكي نلاحظ بعده انه ظهرت قيمة إضافية في الريجستر مستخدم جديد مخفي باسم AtomicOperator$

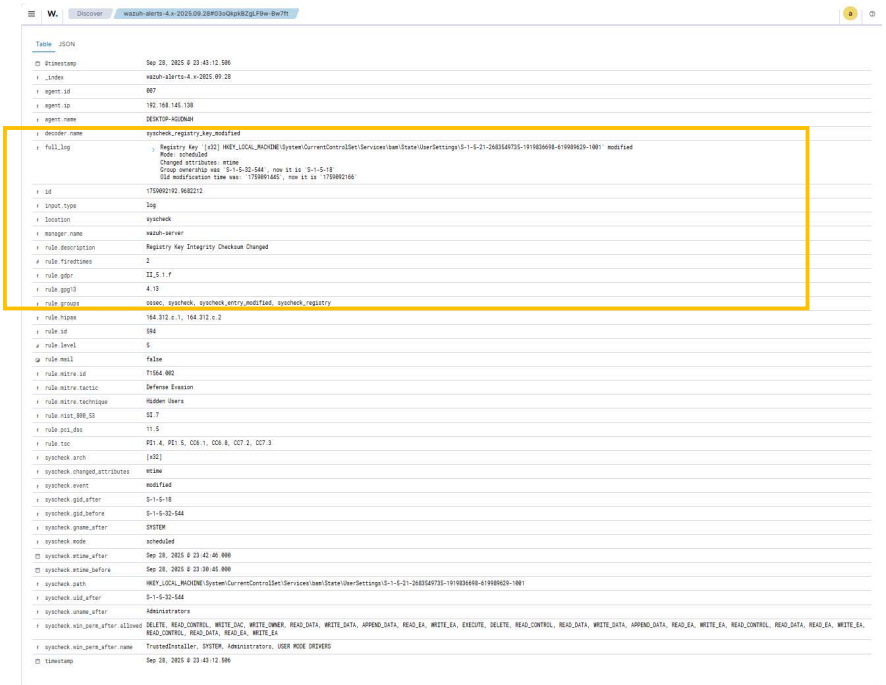




هنا صورة من
Wazuh
هنا نرى تعديل قيمة الريجستري يانها تمت



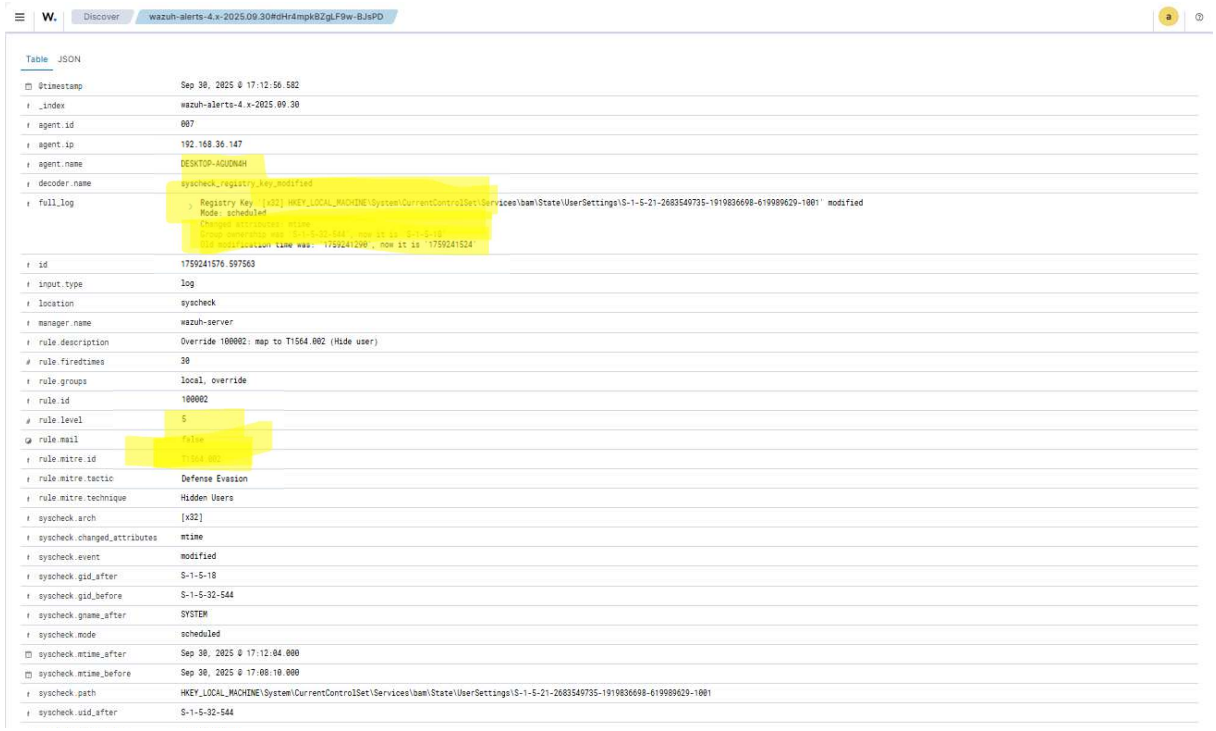
هنا



هنا بعد ا عملت محاكاة ب Payloadمراقبة ينشئ ويحول البيانات الى جهازي كالي



هنا نلاحظ انه قد تم
تغيير ملكية المجموعة من Administrators (S-1-5-32-544) إلى SYSTEM (S-1-5-18)

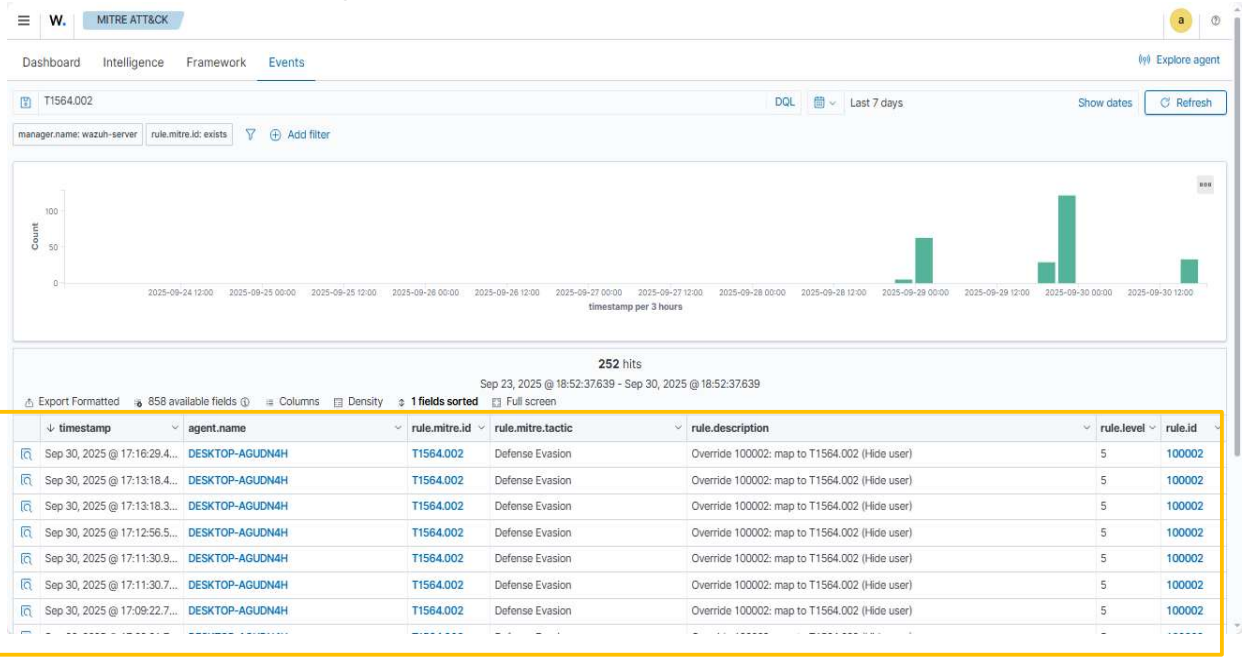


ت

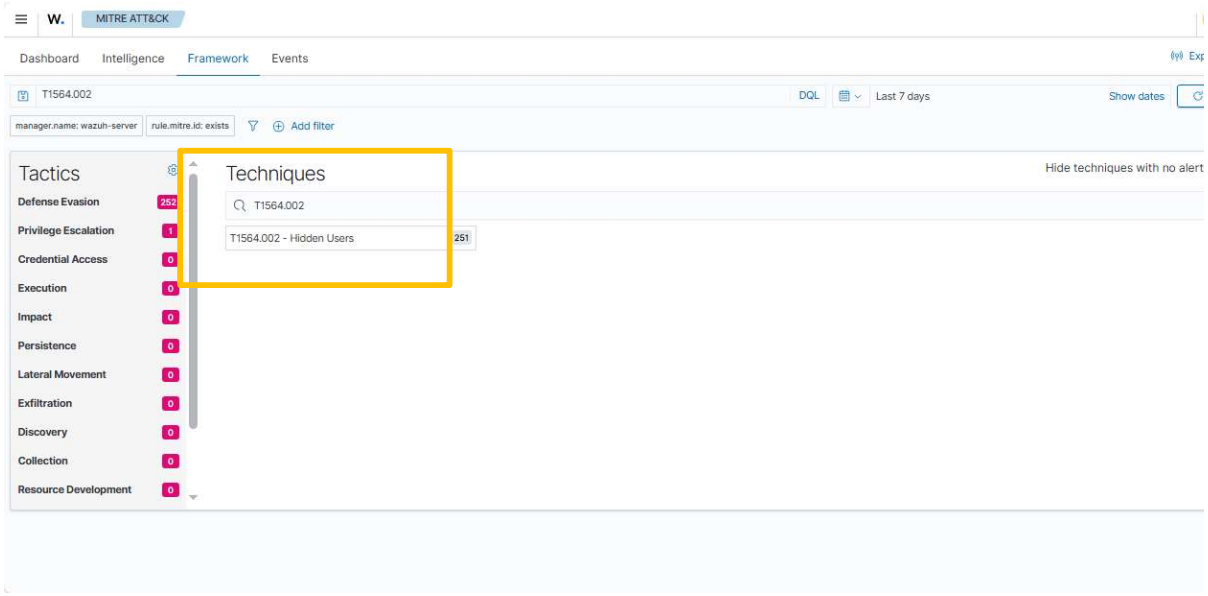

Discover
wazuh-alerts-4.x-2025.09.30#d3r4mpkBZgLF9w-BjMNk
N
np Sep 30, 2025 @ 17:13:18.366
wazuh-alerts-4.x-2025.09.30
007
192.168.36.147
ne DESKTOP-AGUDN4H
name syscheck_registry_key_modified
Registry Key '[x32] HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\W32Time\SecureTimeLimits\RunTime' modified
Mode: scheduled
Changed attributes: mtime
Group ownership was 'S-1-5-32-544', now it is 'S-1-5-18'
Old modification time was: '1759241396', now it is '1759241517'
1759241598.600906
pe log
syscheck
name wazuh-server
cription Override 100002: map to T1564.002 (Hide user)
edtimes 31
ups local, override
100002
el 5
l false
re.id T1564.002
re.tactic Defense Evasion
re.technique Hidden Users
.arch [x32]
.changed_attributes mtime
.event modified
.gid_after S-1-5-18
.gid_before S-1-5-32-544
.gname_after SYSTEM
.mode scheduled
.mtime_after Sep 30, 2025 @ 17:11:57.000
.mtime_before Sep 30, 2025 @ 17:09:56.000
.path HKEY_LOCAL_MACHINE\System\CurrentControlSet\Services\W32Time\SecureTimeLimits\RunTime
.uid_after S-1-5-32-544
.uname_after Administrators
.win_perm_after.allowed
GENERIC_READ, READ_CONTROL, READ_DATA, READ_EA, WRITE_EA, GENERIC_ALL, DELETE, READ_CONTROL, WRITE_DAC, WRITE_OWNER, READ_DATA, WRITE_DATA, APPEND_DATA, READ_EA, WRITE_EA, EXECUTE, GENERIC_ALL, DELETE, READ_CONTROL, WRITE_DAC, WRITE_OWNER, READ_DATA, WRITE_DATA, APPEND_DATA, READ_EA, WRITE_EA, EXECUTE, GENERIC_READ, READ_CONTROL, READ_DATA, READ_EA, WRITE_EA, GENERIC_READ, READ_CONTROL, READ_DATA, READ_EA, WRITE_EA, GENERIC_READ, READ_CONTROL, READ_DATA, READ_EA, WRITE_EA, GENERIC_READ, GENERIC_WRITE, DELETE, READ_CONTROL, READ_DATA, WRITE_DATA, APPEND_DATA, READ_EA, WRITE_EA
.win_perm_after.name Users, Administrators, SYSTEM, NETWORK SERVICE, LOCAL SERVICE, S-1-5-32-556, autotimesvc
Sep 30, 2025 @ 17:13:18.366

هنا لقطة من واجهة MITREE ATT&CK -EVENT -wazuh

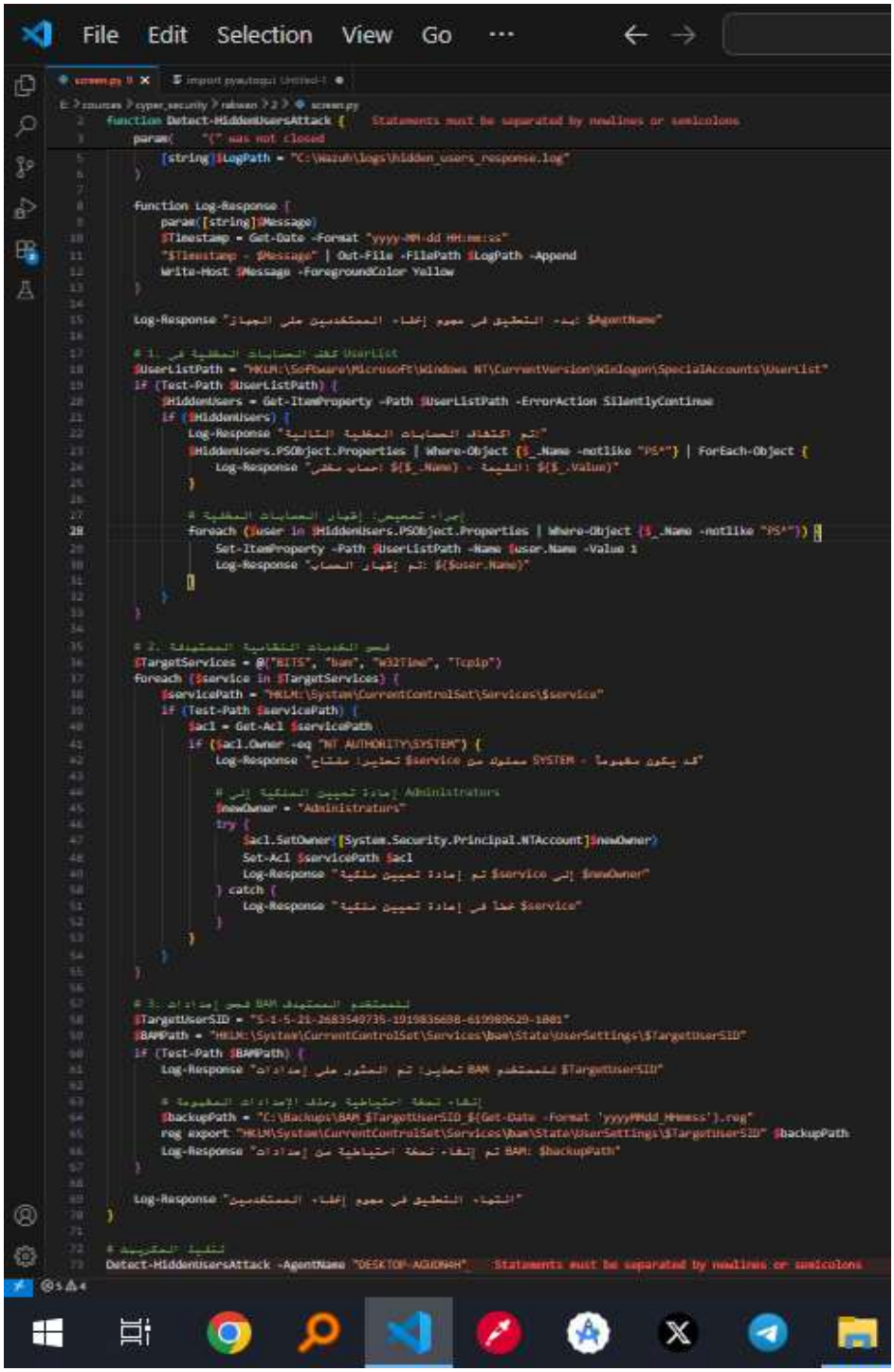
التصنيف ضمن إطارMITRE ATT&CK
التكتيكات والتقنيات المستخدمة
التكتيك التقنية الوصف الدليل
Defense Evasion T1564.002 - Hidden Users إخفاء المستخدمين والمفاتيح النظامية



هنا لقطة من واجهة MITREE ATT&CK - Techniques -wazuh



سكريت استجابة آلي:



توصيات لفريق الـSOC

توصيات فورية:

مراجعة الحسابات المخفية :فحص مفتاح UserList للحسابات المخفية

مراجعة التعديلات :تدقيق التغييرات في المفاتيح النظامية المستهدفة

عزل الجهاز :في حالة الشك بعملية اختراق حقيقية

توصيات تقنية:

تعزيز المراقبة:

مراقبة أي تغييرات في ملكية مفاتيح النظام الحرجة

تطبيق قواعد صارمة لمراقبة مفاتيحBAM, BITS, W32Time, TCP/IP

مراقبة تعديلات مفتاحWinlogon\UserList

تطبيق سياسات أمنية:

تقييد صلاحيات تعديل المفاتيح النظامية

تطبيق مبدأ Least Privilege للوصول إلى الريجستري

مراجعة دورية للحسابات وإعدادات النظام

الخاتمة

من خلال تحليل هذه الحادثة، تعلمنا كيفية اكتشاف هجوم متقدم يستخدم تقنية إخفاء المستخدمين بطريقة غير تقليدية وتقليدية.
الهجوم أظهر كفاءة في استهداف مناطق متعددة من النظام لإخفاء الآثار بشكل شامل.
نجحت منصة Wazuh في كشف جميع مراحل الهجوم قواعد الكشف المتقدمة وربطها بإطار.MITRE ATT&CK

الدروس المستفادة:

---

1. **أهمية مراقبة تغييرات ملكية مفاتيح النظام**
2. **ضرورة مراقبة المفاتيح النظامية في أماكن غير متوقعة**
3. **فعالية تصنيف MITRE ATT&CK في فهم استراتيجية الهجوم**
4. **الحاجة لاستجابات آلية سريعة للهجمات المتقدمة**